

Legal Risk Brief – Penetration Testing Memo

To: Client From: Governance & Risk Consultant Subject: Legal Risks of Penetration Testing

Purpose

This memo summarizes the major legal risks associated with penetration testing under the CFAA (18 U.S.C. § 1030) and Washington State RCW 9A.90, and explains how proper authorization protects both parties.

1. Five Legal Risks Without Authorization

- Unauthorized Access — Accessing any system or account without explicit permission.
- Exceeding Authorized Access — Going beyond the approved scope, even unintentionally.
- Intentional Damage — Causing outages, data loss, or service disruption during testing.
- Trafficking in Credentials — Sharing or storing passwords or tokens obtained during testing.
- Deceptive Information Gathering — Social engineering or impersonation without written approval.

2. Federal vs. Washington State Difference

- CFAA: Criminalizes unauthorized access itself, even if no harm occurs.
- RCW 9A.90: Focuses more on malicious intent and actual system impairment.

Summary: CFAA is broader; Washington law is more intent-based.

3. Indemnification

Indemnification protects the tester from liability for accidental damage that occurs during an authorized test. It ensures the client accepts the inherent risks of testing and covers restoration costs if an unintentional outage or crash occurs within scope.

Conclusion

Penetration testing is only legal when it is authorized, scoped, and documented. Proper agreements—Rules of Engagement, Permission to Test, and indemnification—are essential to avoid violations of the CFAA or the RCW.